

Orientierungshilfe für Unternehmen:

Technisch-organisatorische Maßnahmen gem. Art. 24 und 32 DSGVO

1	Vertraulichkeit	J/N/E
1.1	Allgemeine Prozesse	
A	Es besteht ein betriebsinternes Datenschutz-Management, dessen Einhaltung ständig überwacht wird, sowie anlassbezogen und mindestens halbjährlich evaluiert wird.	
B	Es besteht ein Datenschutzkonzept, welches die Wahrung der Rechte der Betroffenen (Auskunft, Berichtigung, Einschränkung, Löschung der Verarbeitung, Datentransfer, Widerrufe & Widersprüche innerhalb der gesetzlichen Frist gewährleistet. Es umfasst Formulare, Anleitungen und eingerichtete Umsetzungsverfahren, sowie die Benennung der für die Umsetzung zuständigen Personen.	
C	Es besteht ein Datenschutzkonzept, dass eine unverzügliche und den gesetzlichen Anforderungen entsprechende Reaktion auf Verletzungen des Schutzes personenbezogener Daten (Prüfung, Meldung, Dokumentation) gewährleistet. Es umfasst Formulare, Anleitungen und eingerichtete Umsetzungsverfahren, sowie die Benennung der für die Umsetzung zuständigen Personen.	
D	Es werden nicht mehr personenbezogene Daten erhoben, als für den jeweiligen Zweck erforderlich sind.	
E	Es liegt ein Verzeichnis der Verarbeitungstätigkeiten (VVT) vor.	
F	Es liegt ein Löschkonzept vor.	
G	Es wurde ein DSB (Datenschutzbeauftragter) benannt und an die Aufsichtsbehörde gemeldet.	
H	Der DSB führt regelmäßig interne Audits durch und berichtet dem Verantwortlichen.	
I	Es wurde ein ISB (Informationssicherheitsbeauftragter) benannt.	
J	Alle Mitarbeiter kennen die Abläufe bei Datenpannen.	
K	Mitarbeiter werden im Hinblick auf den Datenschutz auf Verschwiegenheit verpflichtet, belehrt und instruiert, als auch auf mögliche Haftungsfolgen hingewiesen. Sofern Mitarbeiter außerhalb betriebsinterner Räumlichkeiten tätig werden oder Privatgeräte für betriebliche Tätigkeiten einsetzen, existieren spezielle Regelungen zum Schutz der Daten in diesen Konstellationen und der Sicherung der Rechte von Auftraggebern einer Auftragsverarbeitung.	
L	Die an Mitarbeiter ausgegebenen Schlüssel, Zugangskarten oder Codes, sowie im Hinblick auf die Verarbeitung personenbezogener Daten erteilten Berechtigungen, werden nach deren Ausscheiden aus dem Unternehmen, bzw. dem Wechsel der Zuständigkeiten eingezogen, bzw. entzogen.	
M	Der Schutz von personenbezogenen Daten wird unter Berücksichtigung des Stands der Technik, der Implementierungskosten und der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung, sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere der mit der Verarbeitung verbundenen Risiken für die Rechte und Freiheiten natürlicher Personen bereits bei der Entwicklung, bzw. Auswahl von Hardware, Software, sowie Verfahren, entsprechend dem Prinzip des Datenschutzes durch Technikgestaltung und datenschutzfreundliche Voreinstellungen berücksichtigt (Art. 25 DSGVO)	

N	Alle Mitarbeiter werden regelmäßig zum Datenschutz geschult. Mindestens 1x jährlich. Neue Mitarbeiter erhalten eine Datenschutzeinweisung vor ihrer Arbeitsaufnahme.	
O	Einfache Ausübung des Widerrufsrechtes des Betroffenen durch technische Maßnahmen.	
P	Eine Cloudnutzung wurde auf Rechtmäßigkeit geprüft.	
Q	Die eingesetzte Software wird stets auf dem aktuell verfügbaren Stand gehalten, ebenso wie Virens Scanner und Firewalls.	
R	Genutzte Software entspricht den Anforderungen nach Art. 25 DSGVO (privacy by default / design)	
S	Das Reinigungspersonal, Wachpersonal und übrige Dienstleister, die zur Erfüllung nebensächlicher Aufgaben herangezogen werden, werden sorgfältig ausgesucht und es wird sichergestellt, dass sie den Schutz personenbezogener Daten beachten.	
T	Bei der Weitergabe von Daten wird die Rechtmäßigkeit eingehalten und erfolgt in dokumentierter Weise. Es werden, wenn erforderlich Verträge zur Auftragsverarbeitung oder gemeinsamen Verantwortung geschlossen	
U	Der DSB prüft vor dem ersten Einsatz und danach regelmäßig unsere Auftragsverarbeiter und deren Verträge, sowie die TOMs zu dem AV-Vertrag.	
V	Abschluss der notwendigen Vereinbarung zur Auftragsverarbeitung bzw. EU-Standarddatenschutzvertragsklauseln	
W	Verpflichtung der Mitarbeiter des AV auf die Vertraulichkeit gem. Art. 28 (3) lit. b DSGVO	
X	Verpflichtung zur Bestellung eines DSB durch den AV (Auftragnehmer), sobald eine gesetzliche Pflicht besteht.	
Y	Regelung zum Einsatz weiterer Sub-Unternehmen im AVV wurde festgelegt	
Z	Auswahl von Auftragnehmern unter Sorgfaltsgesichtspunkten im Bezug auf Datenschutz und -sicherheit	
AA	Schriftliche Festlegung der Weisungen an den Auftragnehmer	
AB	Vereinbarungen von wirksamen Kontrollrechten gegenüber Auftragnehmern	
AC	Eindeutige Vertragsgestaltung (AVV/RAVV) wird sichergestellt	
AD	Sicherstellung der Vernichtung von Daten nach Beendigung des Auftrages	
AE	Datenweitergabe an Dritte nur auf dokumentierte Weise (geschlossener AVV)	
AF	Formalisiertes Auftragsmanagement	
AG	Die Verarbeitung von Daten wird größtmöglich auf die EU beschränkt.	
1.2	Zutrittskontrolle	J/N/E
A	Gebäude ist nachts verschlossen	
B	Manuelles Schließsystem	
C	Sicherheitsschlösser	
D	Schlüsselordnung und Schlüsselverzeichnis sind vorhanden.	
E	Dauerhaft Personal anwesend (Empfangstresen, o.ä.)	
F	Elektrische Türöffner	
G	Außentür mit Knauf	
H	Klingelanlage mit Kamera	
I	Technische Zutrittssysteme (Chipkarten/Transponder)	
J	Technische Zutrittssysteme (Zahlencode)	
K	Technische Zutrittssysteme (Biometrisch)	
L	Fenstersicherung	
M	Absicherung von Gebäudeschächten	
N	Videoüberwachung der Eingänge	
O	Videoüberwachung innerhalb der Gebäude	

P	Alarmanlage wird eingesetzt	
Q	Zutritt zum Bürogebäude / Geschäftsräumen haben nur berechtigte Mitarbeiter	
R	Besucherregelung (z.B. erst nach Türöffnung Zutritt)	
S	Ausweispflicht für Mitarbeiter / Besucher (sichtbar getragen)	
T	Besuche werden protokolliert	
U	Besucher müssen im Gebäude begleitet werden	
V	Beaufsichtigung von Hilfskräften	
W	Serverraum zusätzlich gesichert (Zutritt nur für berechtigtes Personal, z.B. Geschäftsführung und Administrator)	
X	Wachpersonal oder Pförtner im Einsatz	
1.3	Zugangskontrolle	J/N/E
A	Richtlinie zu Login- und Passwortregeln	
B	Mindestpasswortlängen und Passwortmanager nach BSI-Standard	
C	Passwörter werden verschlüsselt gespeichert	
D	Authentifikation mit zusätzlichem Faktor (2FA/MFA) bei erhöhtem Schutzbedarf	
E	Login mit biometrischen Daten wird angewendet.	
F	Protokollierung von Zugriffen auf Anwendungen und Daten, konkret bei der Eingabe, Änderung und Löschung von Daten.	
G	BIOS-Schutz (separates Passwort)	
H	Datenschutztresor wird genutzt	
I	Verschließbare Aktenschränke (z.B. für Personal-Akten)	
J	Berechtigungs-/Authentifizierungskonzepte mit bis auf das Nötigste beschränkten Zugriffsrechten	
K	Sperren von externen Schnittstellen (USB, Thunderbolt, etc.)	
L	Verschlüsselung von internen Festplatten wird umgesetzt	
M	Verschlüsselung von externen Datenträgern und Geräten	
N	Mobile Geräte, Server und Rechner verfügen über eine Virens Scanner-Lösung	
O	Einsatz von VPN-Technologie	
P	Einsatz einer Firewall (Software)	
Q	Einsatz einer Firewall (Hardware)	
R	Einsatz von zentraler Smartphone-Administrations-Software	
S	Sichtschutz der Arbeitsplatzmonitore	
T	Richtlinie zum Einsatz von USB-Sticks und externer Laufwerke	
U	Automatische Desktopsperre mit Passwortschutz	
V	Vergabe der Rechte durch Administratoren, bei Beachtung einer minimalen Anzahl von Admins.	
W	Fehlerhafte Eingaben bei Systemzugriffen werden protokolliert und führen nach einer dezidierten Anzahl von Zugriffsversuchen zur Sperrung des Zuganges	
X	Einsatz von Intrusion-Detection-Systemen und regelmäßiger Auswertung durch einen Admin	

1.4	Zugriffskontrolle	J/N/E
A	Berechtigungen klar nach Zuständigkeiten trennen	
B	Vernichtung von Papier oder die physische Löschung digitaler Daten, wird gem. DIN 66399 durchgeführt. Wird ein ext. Dienstleister damit beauftragt, wird ein Nachweis der ordnungsgemäßen Löschung / Vernichtung nach DIN 66399 eingeholt.	
C	Regelungen treffen, dass Mitarbeiter keine Veränderungen an Hard- oder Software vornehmen dürfen. (IT-Richtlinie erstellen)	
D	Regelungen zu privater Nutzung von E-Mail und Internet treffen.	
1.5	Trennung	J/N/E
A	Physische Mandantentrennung (Hardware)	
B	Logische Mandantentrennung (Software)	
C	Physische Trennung von Systemen, Datenbanken, Datenträgern	
D	Trennung von Produktiv- und Testsystem	
E	Sandboxing	
F	Steuerung über Berechtigungskonzept	
G	Festlegung von Datenbankrechten	
H	Datensätze sind mit Zweckattributen versehen	
I	Bei pseudonymisierten Daten: Trennung der Zuordnungsdatei und der Aufbewahrung auf einem getrennten, abgesicherten System – möglichst verschlüsselt gespeichert.	
1.6	Pseudonymisierung und Verschlüsselung	J/N/E
A	Remote Zugriffe nur verschlüsselt (VPN)	
B	Mobile Datenträger sind verschlüsselt	
C	Webseiten werden verschlüsselt betrieben	
D	E-Mail-Verschlüsselung wird angewendet	
E	Ende-zu-Ende Verschlüsselung bei Messengerdiensten	
F	Möglichst viele Daten pseudonymisieren (Kundennummern verwenden). Zuordnungsdatei ist getrennt und sicher gespeichert, sowie verschlüsselt.	
G	Interne Anweisung, personenbezogene Daten zu anonymisieren, wenn diese nach Ablauf der Löschfrist weiter genutzt werden soll (z.B. statistische Erhebung)	
H	Interne Anweisung, personenbezogene Daten im Falle einer Weitergabe möglichst zu pseudonymisieren.	
2	Integrität	J/N/E
A	Veränderungen an Daten müssen protokolliert werden	
B	Mitarbeiter müssen mit ihrem eigenen Account arbeiten (keine Weitergabe von Passwörtern)	
C	Es müssen Berechtigungskonzepte vorliegen (für jede Software und geteilte Datenordner)	
D	Sichere Weitergabe von Daten (signieren von E-Mails) mit dezidierte Weitergabe-Berechtigung	
E	Protokollierung bei Veränderung von Daten	
F	Protokolle werden geprüft (manuell oder automatisch)	
G	Getrennte Partitionen für Betriebssysteme und Software	
H	Berechtigungskonzepte finden Anwendung für Software und geteilte Ordner	

3	Intervenierbarkeit	J/N/E
A	Dokumentation der Datenempfänger, der Speicherdauer, den Löschfristen im VVT sind definiert worden.	
B	Es liegt ein Löschkonzept vor	
C	Die Betroffenen sind über ihre Rechte informiert worden und das Unternehmen hat Maßnahmen ergriffen, dass diese gewahrt und bei Bedarf umgesetzt werden.	
4	Verfügbarkeit, Belastbarkeit und Wiederherstellbarkeit	J/N/E
A	Regelmäßige Sicherung der Daten (Backup), min. 1x / Woche, mehrere verschiedene Sicherungen, räumlich getrennt und an geschützten Orten	
B	Täglich inkrementelle Sicherung und wöchentliche Komplettsicherung	
C	Regelmäßiges Testen einer Rücksicherung (Wiederherstellen)	
D	Einsatz von RAID-Systemen	
E	Einsatz von Festplattenspiegelung	
F	Datenschutztesor nach DIN S60DIS / S120DIS vorhanden	
G	Ständig kontrolliertes Backup- und Recovery-Konzept (ausformuliertes Konzept)	
H	Regelmäßiges Testen einer Rücksicherung inklusive Protokollierung der Ergebnisse	
I	Sicherstellung einer funktionsfähigen Klimatisierung	
J	Einsatz einer unterbrechungsfreien Stromversorgung (USV) und Überspannungsschutz der wichtigsten Systeme / des Servers	
K	Durchführung von Belastbarkeitstests	
L	Temperaturüberwachung im Serverraum wird eingesetzt	
M	CO2-Feuerlöscher nahe Serverraum vorhanden	
N	Serverraum ist klimatisiert	
O	Serverraum ist videoüberwacht	
P	Alarmmeldung bei unberechtigtem Zutritt zum Serverraum	
Q	Feuchtigkeitsüberwachung im Serverraum wird eingesetzt	
R	Keine sanitären Anschlüsse im oder oberhalb des Serverraumes	
S	Sicherungsmedien werden nicht im Serverraum verwahrt	
T	Schutzsteckdosenleisten im Serverraum	
U	Es liegt ein Notfallplan vor (Feuer, Wasser, Sturm, Einbruch, Stromausfall, Einbruch, Cyber-Attacke, Datenpanne, etc.)	
V	Notfallkonzept mit Redundanzverfahren	
W	Feuer-, Rauch-, Brandmeldeanlage	
X	Persönliche Protokollierung bei Datentransport (Lieferung)	
Y	Sichere Transportbehälter, sorgfältige Auswahl bei Personal und Fahrzeugen	
Z	Aufbewahrung von Formularen, von denen Daten in automatisierte Verarbeitung übernommen wurden (Rechenschaftspflicht)	
AA	Klare Zuständigkeiten für Daten-Löschungen sind festgelegt.	

5	Verfahren zur regelmäßigen Überprüfung, Bewertung & Evaluierung	J/N/E
A	Es wurde ein Datenschutzkonzept erstellt	
B	Alle Mitarbeiter kennen die Abläufe bei Datenpannen	
C	Die Datenverarbeitung sollte auf die EU beschränkt werden	
D	Datenweitergabe an Dritte nur auf dokumentierte Weise (z.B. AVV)	
E	Genutzte Software muss den Anforderungen des Art. 25 DSGVO entsprechen (Privacy by design / default)	
F	Privacy-by-..., z.B. suchen von Datensätzen und umfangreiche Löschung muss möglich sein, Protokollierung von Eingaben, Berechtigungen, privater Modus, Einschränkungen der Bildschirmmaske, Möglichkeiten des Sperrens, etc.	
G	Es wurde ein DSB und ein ISB benannt	
H	DSB führt regelmäßig interne Audits durch und berichtet dem Verantwortlichen	
6	Datenschutz-Management	J/N/E
A	Einsatz eines Datenschutz-Managements (z.B. SaaS)	
B	Zentrale Dokumentation aller Verfahrensweisen und Regelungen zum Datenschutz mit Zugriff für alle Mitarbeiter nach Bedarf / Berechtigung (per Intranet oder Zugang zum SaaS)	
C	ISO 27001 Zertifikat erworben	
D	BSI-IT-Grundschutz / ISIS 12	
E	Anderes dokumentiertes Sicherheitskonzept	
F	Wirksamkeitstest der TOMs mindestens 1x jährlich durchgeführt	
G	Es wurde ein DSB benannt und dessen Kontaktdaten veröffentlicht	
H	Die Einbindung des DSB zu Datenschutzfragen wird umgesetzt	
I	Es wurde ein ISB benannt und dessen Kontaktdaten veröffentlicht	
J	Die Einbindung des ISB zu Sicherheitsfragen wird umgesetzt	
K	Sensibilisierung und Schulung der Mitarbeiter finden regelmäßig statt (mindestens jährlich, dokumentiert)	
L	Leit- und Richtlinien zur Informationssicherheit und dem Datenschutz sind definiert und von der Geschäftsführung genehmigt, sowie den Mitarbeitern eröffnet worden	
M	Rollen und Verantwortlichkeiten im Bereich der Sicherheit und im Datenschutz sind im Unternehmen bekannt und besetzt	
N	Mitarbeiter werden in dokumentierter Weise zur Vertraulichkeit / Geheimhaltung verpflichtet (das bezieht sich auch auf den Onboarding-Prozess neuer Mitarbeiter vor Arbeitsaufnahme)	
O	Das Datenschutz-Managementsystem stellt eine kontrollierte Bearbeitung von Anfragen Betroffener sicher. Die Einhaltung von Fristen wird durch das System überwacht und an Verantwortliche gemeldet.	
P	Die Organisation / das Unternehmen kommt den Informationspflichten nach Art. 13 und 14 DSGVO nach.	
Q	Datenschutz-Folgenabschätzungen (DSFA) werden bei Bedarf (z.B. Einsatz KI-System) durchgeführt und ein DSB hinzugezogen	

7	Incident-Response-Management	J/N/E
A	Einsatz von Firewall mit regelmäßiger Aktualisierung	
B	Einsatz von Spamfilter mit regelmäßiger Aktualisierung	
C	Einsatz von Virens Scanner mit regelmäßiger Aktualisierung	
D	Einsatz eines Intrusion-Detection-Systems (IDS)	
E	Einsatz eines Intrusion-Prevention-Systems (IPS)	
F	Dokumentierter Prozess zur Erkennung und Meldung von Sicherheitsvorfällen / Datenpannen (auch im Hinblick auf Meldepflichten gegenüber Aufsichtsbehörden)	
G	Dokumentierte Vorgehensweise zum Umgang mit Sicherheitsvorfällen	
H	Einbindung eines DSB bei Datenpannen oder Betroffenenanfragen oder Fragen von Aufsichtsbehörden	
I	Einbindung eines ISB bei Sicherheitsfragen	
J	Dokumentation von Sicherheitsvorfällen und Datenpannen via Ticketsystem oder DSMS	
K	Formaler Prozess und Verantwortlichkeiten zur Nachbearbeitung von Sicherheitsvorfällen und Datenpannen (wie PDSC-Zyklus, QM, KVP, o.ä.)	

J: ja

N: nein

E: entfällt